تقرير تدقيق أمن الموقع الإلكتروني

فحص سلبي باستخدام OWASP ZAP 2.17.0 | مقارنة المحلي بالإنتاج | ٢ نوفمبر ٢٠٢٦

٠١ / الملخص التنفيذي

يستند هذا التقرير إلى نتيجتين لفحص OWASP ZAP Baseline قدمتهما مالكة الموقع. لم تُجرَ محاولات استغلال يدوية أو عمليات تحقق مستقلة. لم يُسجّل فحص بيئة الإنتاج أي تنبيه عالي الخطورة. تشير التنبيهات الأخرى إلى إعدادات قابلة للتحسين وإجراءات لتعزيز الحماية، ولا تُثبت اختراقاً أو وجود ثغرات قابلة للاستغلال. الأولوية لمراجعة واجهة نموذج الاتصال وسياسة CORS.

الإنتاج: صفر تنبيهات عالية، و٤ فئات متوسطة، وفئتان منخفضتان، و٥ فئات معلوماتية؛ ٤١ نقطة نهاية. المحلي: صفر عالية، و٦ متوسطة، و٦ منخفضة، وفئتان معلوماتيتان؛ ٤٠ نقطة نهاية. تمثل الأرقام فئات تنبيهات وليست عدد ثغرات مؤكدة. صنّف ZAP نسبة ٨١٪ من استجابات الإنتاج على أنها بطيئة، لكن هذه الملاحظة المنفردة لا تكفي للحكم على الأداء الفعلي للمستخدمين.

٠٢ / النطاق والمنهجية

استُخدم OWASP ZAP 2.17.0 بوضع Baseline لفحص نسخة ثابتة محلية ثم الموقع المنشور. شمل الفحص استجابات HTTP والرؤوس والروابط والموارد المكتشفة. لا ينفّذ خادم Python المحلي الوظيفة الحقيقية للمسار api/contact/، بل يعيد HTTP 501. رصد فحص الإنتاج ٤١ نقطة نهاية، ونحو ٩٧٪ من الطلبات كانت GET و٢٪ POST. لم يشمل التقييم استغلالاً نشطاً أو مراجعة شاملة للشيفرة أو اختبار المصادقة أو الضغط أو تسليم البريد الإلكتروني.

٠٣ / النتائج والضوابط الوقائية

F01 | غياب رمز مكافحة CSRF في نموذج الاتصال | متوسط / يحتاج تحقق

رصد ZAP نموذج POST موجهاً إلى /api/contact دون حقل مخفي لرمز CSRF، في موضعين. تعني CSRF دفع المتصفح إلى تنفيذ إجراء غير مرغوب باسم المستخدم، خصوصاً عند إرسال بيانات الجلسة تلقائياً. غياب الرمز عن نموذج عام ومجهول لا يثبت وحده وجود ثغرة؛ وقد تكون الرسائل المزعجة وإساءة الاستخدام واستهلاك الموارد أخطاراً أهم.

مراجعة استخدام الجلسات وملفات تعريف الارتباط في الخلفية؛ التحقق من Origin أو Referer عند الحاجة؛ استخدام رموز CSRF للعمليات الموثقة؛ تحديد معدل الطلبات والتحقق من الحقول على الخادم واستخدام حقل مصيدة كإجراء مساعد وتسجيل السلوك غير الطبيعي. يُفضّل الاختبار في بيئة تجريبية دون إرسال رسائل حقيقية.

F02 | سياسة CSP تسمح بـ unsafe-inline للأنماط | متوسط / إعداد مؤكد

تتضمن السياسة style-src 'self' 'unsafe-inline' https://fonts.googleapis.com. تتحكم CSP في الموارد التي يمكن للمتصفح تحميلها؛ ويسمح unsafe-inline بأنماط CSS المضمنة، مما يضعف القيود على حقن الأنماط. لا يعني ذلك تأكيد وجود XSS. تُعد تجزئات السكربتات و script-src-attr none ضوابط إيجابية موجودة.

حصر الأنماط المضمنة ونقلها إلى ملفات CSS خارجية أو استخدام التجزئات والرموز المؤقتة عند الملاءمة؛ الاختبار أولاً باستخدام Content-Security-Policy-Report-Only؛ الحفاظ على قيود السكربتات و frame-ancestors none، وفحص أخطاء المتصفح والمظهر.

F03 | سياسة CORS تسمح بأي مصدر | متوسط / بحسب السياق

لاحظ ZAP وجود Access-Control-Allow-Origin: * في HTML وCSS و robots.txt و sitemap.xml العامة. تحدد CORS ما إذا كان JavaScript من مصدر آخر يستطيع قراءة الاستجابة. قد يكون الرمز * مناسباً للموارد العامة المقصودة، ولا يثبت تسرب بيانات خاصة؛ لكن استجابات API تتطلب مراجعة منفصلة.

مراجعة قواعد Cloudflare/Workers لكل مسار؛ إزالة CORS غير الضرورية؛ حصر المصادر المسموحة في الواجهات التي تحتاجها؛ منع إرجاع بيانات حساسة من واجهات عامة؛ فحص طلبات preflight واستجابات الأخطاء وعدم الجمع بين المصادر العشوائية وبيانات الاعتماد.

F04 | غياب SRI عن ملفات الأنماط الخارجية | متوسط / تعزيز سلسلة التوريد

تفتقر روابط CSS الخاصة بـ Google Fonts إلى السمة integrity. تتحقق SRI من مطابقة المورد الخارجي لتجزئة متوقعة. قد يختلف CSS الذي تعيده Google Fonts بحسب المتصفح، ولذلك قد يؤدي تثبيت تجزئة واحدة إلى تعطّل الخطوط. لا يثبت هذا التنبيه وقوع اختراق.

استضافة الخطوط وملفات CSS الضرورية محلياً وتقليل عائلات الخطوط؛ استخدام integrity و crossorigin للموارد الخارجية الثابتة ذات الإصدارات المحددة؛ التحقق من المظهر والتوافق بعد التغيير.

F05 | غياب COEP | منخفض / اختياري

يغيب رأس Cross-Origin-Embedder-Policy عن ثلاث استجابات HTML. يمكن أن تساعد COEP مع COOP في عزل المصادر، لكن ليس كل موقع بحاجة إليها. قد يؤدي تفعيل require-corp دون اختبار إلى حجب الخطوط أو الموارد الخارجية.

تقييم الحاجة الفعلية إلى العزل؛ اختبار توافق الاعتمادات الخارجية؛ عدم تفعيل require-corp أو credentialless إلا بعد تبرير تقني واختبارات رجعية.

F06 | غياب HSTS عن استجابتين لواجهة API | منخفض / تحقق حسب المسار

لا يظهر Strict-Transport-Security في استجابتي /api/ و api/contact/، بينما ترسله الصفحة الرئيسية. يوجّه HSTS المتصفح إلى استخدام HTTPS مستقبلاً. غيابه عن بعض المسارات لا يعني أن الموقع يرسل البيانات عبر HTTP غير آمن.

مراجعة Cloudflare/Workers واستجابات الأخطاء؛ توحيد سياسة HSTS وHTTPS حيث يلزم؛ التحقق من إعادة التوجيه من HTTP إلى HTTPS وتقييم تأثير includeSubDomains قبل تفعيله.

٠٤ / التنبيهات المعلوماتية والفروق بين البيئات

تشمل الفئات المعلوماتية الخمس تعليقاً غير ضار في contact-confirmation.js تسببت كلمة "from" في رصده، واستجابات غير قابلة للتخزين، وإعادة التحقق من Cache-Control، وتخزين الموارد العامة مؤقتاً، واستجابات تتطلب التحقق قبل إعادة استخدامها. لا تثبت هذه الأمور وقوع حادث أمني. لا يحاكي خادم Python المحلي رؤوس Cloudflare أو Workers؛ لذا لا يجوز نقل تنبيهاته بشأن clickjacking أو nosniff أو Permissions-Policy أو كشف إصدار Python إلى بيئة الإنتاج مباشرة. ويعني ظهور صفر إيجابيات كاذبة في ZAP أنه لم تُعلّم أي تنبيهات يدوياً على أنها خاطئة.

٠٥ / خطة المعالجة حسب الأولوية

الأولوية P1 خلال ١–٣ أيام: مراجعة التحقق من المدخلات وOrigin وتحديد معدل الطلبات ومكافحة الرسائل المزعجة والاعتماد على الجلسات في /api/contact؛ ومراجعة CORS في واجهات API واستجابات الأخطاء. الأولوية P2 خلال أسبوع إلى أسبوعين: تقليل Google Fonts أو استضافتها محلياً؛ إزالة unsafe-inline تدريجياً بعد اختبار Report-Only؛ والتحقق من اتساق HSTS. الأولوية P3 عند الحاجة: تقرير جدوى COEP. باستمرار: إعادة فحص ZAP بعد التغييرات، وحفظ أدلة مؤرخة، وقياس LCP وINP وCLS، وتحديث الاعتمادات، وإبعاد الأسرار عن المستودع، وتوثيق المخاطر المتبقية.

٠٦ / مسرد المصطلحات التقنية

نقطة النهاية Endpoint: مسار HTTP مثل /api/contact. رموز HTTP 2xx/3xx/4xx/5xx: نجاح/إعادة توجيه/خطأ من العميل/خطأ من الخادم. GET لجلب البيانات وPOST لإرسالها عادةً. رأس HTTP: بيانات وصفية للاستجابة. CSP: سياسة تحميل الموارد. CSRF: تزوير الطلبات عبر المواقع. CORS: أذونات القراءة بين المصادر. SRI: تجزئة للتحقق من سلامة المورد الخارجي. HSTS: إلزام المتصفح باستخدام HTTPS. COEP/COOP/CORP: سياسات عزل المصادر والموارد. X-Frame-Options وframe-ancestors: حماية من clickjacking. nosniff: منع تخمين نوع الملف. Cache-Control: قواعد التخزين المؤقت. الإيجابية الكاذبة: تنبيه يتبين عدم انطباقه بعد التحقق. الخطر المتبقي: الخطر بعد تطبيق الضوابط.

٠٧ / الأدلة والمراجع والقيود

الأدلة الأساسية: تقريرا OWASP ZAP Baseline المحلي والإنتاجي بتاريخ ٢ نوفمبر ٢٠٢٦، ورؤوس HTTP للإنتاج التي قدمتها المالكة. مراجع تقنية قابلة للتحقق: OWASP ZAP Baseline Scan، ودليلا OWASP لمنع CSRF وسياسة CSP، ووثائق MDN حول CORS وSRI وHSTS وCOEP، ومشروع OWASP Secure Headers. الثقة مرتفعة في وجود الرؤوس المذكورة ضمن الأدلة المقدمة، ومتوسطة في تقدير الأثر لغياب شيفرة الخلفية وإعدادات Cloudflare والاختبارات الوظيفية والسجلات. هذا تفسير تقني لفحص سلبي آلي، وليس شهادة أمنية أو اختبار اختراق شاملاً.

https://www.zaproxy.org/docs/docker/baseline-scan/

https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html

https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html

https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CORS

https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Strict-Transport-Security

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy

https://owasp.org/www-project-secure-headers/